

NARRATIVA EXPLICATIVA Y CONTEXTO

Tono Irónico, Literario y Alegre

Una Odisea Cibernética: Midiendo lo Medible (y lo Imposible) en Tiempos de Amenazas Persistentes

Versión: 1.0 | Enero 2026

PRÓLOGO: EL ARTE PERDIDO DE CONOCER QUÉ ESTÁ PASANDO

Imagina esto: Eres CISO. Te has desayunado con tres emails de *ejecutivos preocupados* preguntándose si están *realmente* seguros, la Junta quiere ROI (sí, ROI de no-ser-hackeado, ese número mágico), y tu equipo de 4 personas está entre apagar incendios, parchear cosas, y escribir políticas que nadie leerá.

¿Cómo demuestras valor sin números? ¿Cómo convences al CFO de que gastar €500k en SIEM es una "inversión" y no un "gasto"?

Bienvenido a la Encuesta Integral de Ciberseguridad: El arte de **convertir caos en métricas, incertidumbre en insights, y (con suerte) políticos en creyentes.**

ACTO I: ¿POR QUÉ MEDIR CIBERSEGURIDAD ES COMO INTENTAR COGER AGUA CON LAS MANOS?

La Paradoja del CISO Moderno

La ciberseguridad es quizás el único campo donde:

1. Éxito = Nada ocurrió (ausencia de incidentes)
2. Fracaso = Todos lo saben (breach en primera plana)
3. Presupuesto = Inversión invisible (gastan en algo que nadie ve)

Por eso los CISOs tienen alta rotación y estrés. Si nada pasa — "¿para qué tanto gasto?" Si algo pasa — "¿por qué pasó si contratamos al CISO?"

Solución: Medir. Constantemente. Con números.

Introducción al Mundo de las Métricas

Esta encuesta es esencialmente una traducción del caos en **seis preguntas grandes** (NIST CSF) que desglosamos en **50+ preguntas específicas** que luego convertimos en **números mágicos (0-5)** que se promedian en un índice (IGM) que supuestamente dice "qué tal estamos".

Suena absurdo. Probablemente lo es. Pero funciona.

ACTO II: LOS SEIS PILARES DEL CASTILLO DIGITAL

Pilar 1: GOBERNAR (¿Quién Manda Aquí?)

Metáfora: Un barco sin capitán es un desastre. Un barco con capitán pero sin brújula es otro desastre. Un barco con capitán, brújula, pero sin mapa... bueno, quizás con suerte.

En términos NIST: ¿Existe política? ¿Hay CISO? ¿El CISO reporta al CEO o al Director de TI? ¿Hay presupuesto o es limosna?

Por qué importa:

- 48% de las brechas comienzan porque nadie tenía claro quién debía haber hecho qué
- El CISO sin autoridad ejecutiva es como Superman sin poderes: excelentes intenciones, cero impacto

Preguntas Clave:

- ¿Existe política de ciberseguridad documentada?
- ¿Reporta el CISO a CEO o a TI?
- ¿Hay comité de gobernanza?
- ¿Se cumple NIS2/GDPR/ISO 27001?

Realidad España 2025: 42% de empresas medianas NO tienen CISO formalizado. 60% de CISOs reportan a CTO (no CEO). Riesgo residual: CRÍTICO.

Pilar 2: IDENTIFICAR (¿Sabemos Qué Tenemos?)

Metáfora: Tienes una casa gigante. ¿Sabes cuántas ventanas tiene? ¿Cuáles están rotas? ¿Dónde están las cerraduras? Si no, los ladrones (atacantes) los descubrirán primero que tú.

En términos NIST: ¿Tenemos inventario de activos? ¿Hacemos escaneo de vulnerabilidades? ¿Priorizamos con CVSS o (inteligentemente) con EPSS?

Por qué importa:

- 70% de brechas en empresas ocurren en sistemas que... nadie sabía que existían
- Sin inventario, es como luchar contra enemigos invisibles en territorio desconocido

Preguntas Clave:

- ¿Cobertura inventario de activos?
- ¿Frecuencia de escaneo de vulnerabilidades?
- ¿Utilizamos EPSS (probabilidad explotación) además de CVSS?
- ¿Qué vulnerabilidades críticas están pendientes?

Realidad España 2025: 55% de organizaciones tienen <70% cobertura inventario. Escaneo promedio: mensual (debería ser semanal en crítica). Adopción EPSS: <20%.

Pilar 3: PROTEGER (¿Tenemos Defensas?)

Metáfora: Conoces tus ventanas. Ahora... ¿cierras las puertas? ¿Instalas alarmas? ¿Haces que alguien verifique que efectivamente se cerraron?

En términos NIST: Pruebas de penetración, controles técnicos, entrenamiento de empleados.

Por qué importa:

- Las defensas importan si están implementadas
- Las más sofisticadas defensa es inútil si no se valida regularmente (pentest)

Preguntas Clave:

- ¿Realizamos pentest regularmente (anual, mínimo)?
- ¿Cobertura: solo perimetral o incluye interno+OT+cloud?
- ¿Qué % de hallazgos se remedia?
- ¿Capacitación en ciberseguridad es continua?

Realidad España 2025: 60% de empresas hacen pentest anual (bueno). 40% tienen scope limitado (malo). Phishing click rate promedio: 12-15% (vs. target <5%).

Pilar 4: DETECTAR (¿Vemos Cuando Atacan?)

Metáfora: Tienes alarmas. ¿Alguien está escuchando? ¿De día? ¿De noche? ¿Cuando es fin de semana? Porque los hackers sí trabajan fin de semana (spoiler: siempre es "fin de semana").

En términos NIST: SIEM, monitorización 24/7, detección de anomalías, MTTD (Mean Time To Detect).

Por qué importa:

- Detectar en 15 minutos vs. detectar en 6 horas = diferencia entre €50k y €500k en impacto
- Falsos positivos = "alarmismo digital" = analista ignora alertas (SIEM inútil)

Preguntas Clave:

- ¿Existe SIEM centralizada?
- ¿% de fuentes de logs centralizadas?
- ¿MTTD (tiempo promedio detección)?
- ¿% de alertas que son realmente accionables?

Realidad España 2025: 45% tiene SIEM. Cobertura promedio: 65%. MTTD: 2-4 horas (vs. target <1h). Falsos positivos: 25-40% (vs. target <5%).

Pilar 5: RESPONDER (¿Reaccionamos Inteligentemente?)

Metáfora: Suena la alarma. Tienes plan o todos corremos en círculos gritando? ¿Quién llama al abogado? ¿Quién desconecta? ¿Quién avisa al CEO?

En términos NIST: Plan de respuesta, equipos designados, SLA de comunicación, MTTC (contención).

Por qué importa:

- Diferencia entre comunicación en 24h vs. 48h = multa GDPR €500k mayor
- Diferencia entre equipo coordinado vs. caos = horas de contención

Preguntas Clave:

- ¿Existe plan formal de respuesta?
- ¿Roles designados (IC, Forensics, Legal, Comms)?

- ¿MTTC (tiempo medio contención)?
- ¿Simulacros anuales realizados?

Realidad España 2025: 64% tiene plan (mejora). 36% sin plan coordinado = vulnerabilidad crítica. MTTC promedio: 6-8 horas (vs. target <4h).

Pilar 6: RECUPERAR (¿Volvemos a la Normalidad?)

Metáfora: Luego del caos, ¿qué queda? ¿Backups? ¿Dónde? ¿Encriptados? ¿Comprobamos que funcionan? O descubrimos que el "backup" era un meme ("sólo confiábamos en la nube").

En términos NIST: RTO/RPO, planes de continuidad, backups, disaster recovery.

Por qué importa:

- RTO/RPO indefinido = no tienen plan de recuperación (solo esperanza)
- Backups sin pruebas = "esperanza y oración" como estrategia (no recomendado)

Preguntas Clave:

- ¿RTO/RPO definido por criticidad?
- ¿Backup aire-gapped (segregado)?
- ¿Pruebas mensuales de recuperación?
- ¿Plan de cyber-recovery separado de DR tradicional?

Realidad España 2025: 36% sin plan coordinado DR/CR. RTO/RPO frecuentemente indefinido. 50% hace pruebas de backup <1/año (debería ser mensual).

ACTO III: LA ARITMÉTICA DEL RIESGO (CÓMO CONVERTIMOS CAOS EN NÚMEROS)

El Viaje de una Respuesta Encuesta → IGM

4. Respondiste encuesta → Seleccionaste opción (A, B, C, D, E)
5. Opción → Puntuación 0-5 (Inexistente → Optimizado)
6. Preguntas → Dominio (6 preguntas sobre GOBERNAR suman en "GV")
7. Dominio × Factor ponderación → Puntuación ponderada
8. 6 Dominios ponderados → Promedio → IGM (0-5)
9. IGM → Nivel Madurez → Riesgo Residual → Recomendaciones

Ejemplo Real: El Viaje de TecnoEmpresa S.L.

TecnoEmpresa es empresa mediana (200 empleados), sector industrial, NO operador CRITIS.

Respuestas Encuesta (resumidas):

Pregunta	Respuesta	Puntos
Política de ciberseguridad	"Existe, comunicada anual"	3/5
CISO reporta a	"Director TI (no CEO)"	2/5
Cumplimiento NIS2	"No aplica (no CRITIS)"	0/5
Inventario activos	"70%, actualizaciones trimestrales"	2/5
Escaneo vulnerabilidades	"Mensual, CVSS únicamente"	2/5
Pentest realizado	"Anual, perimetral"	2/5
SIEM	"Existe, 60% cobertura"	2/5
Plan respuesta incidentes	"Existe, sin simulacro reciente"	2/5
Backup	"Diario, 2 copias, sin aire-gap"	2/5
Concienciación	"Anual, sin phishing sim"	1/5

Cálculo IGM:

- $GV = (3 + 2 + 0) / 3 = 1.7$
- $ID = (2 + 2) / 2 = 2.0$
- $PR = (2 + 1) / 2 = 1.5$
- $DE = 2.0$
- $RS = 2.0$
- $RC = 2.0$

$$IGM = (1.7 + 2.0 + 1.5 + 2.0 + 2.0 + 2.0) / 6 = 1.87$$

Interpretación:

- Maturity 1 (Inicial)
- Riesgo Residual: 60-80% (muy alto)
- Posición: Peor que 60% de pares españoles

Conclusión para TecnoEmpresa: "Gestión cibernética básica, muchos gaps, riesgo inasumible".

ACTO IV: DÓNDE ESTÁN LOS GAPS (LA PARTE QUE DUELE)

Tipos de Gaps Comunes

Gap de Gobernanza:

- "Tenemos CISO, pero reporta a TI, no a CEO" → Autoridad limitada, decisiones lentas
- "Hay política, pero de 2018" → Obsoleta para NIS2, GDPR, cloud

Gap de Identificación:

- "Scaneamos vulnerabilidades, pero con CVSS únicamente" → Priorización incorrecta (remediar lo severo vs. lo probable)
- "Inventario de activos 65%" → 35% invisibles (zona oscura de ataque)

Gap de Protección:

- "Pentest anual, pero solo perimetral" → No ves ataques internos, OT, supply chain
- "Click rate phishing 15%" → Empleados vulnerables al vector más común

Gap de Detección:

- "No tenemos SIEM" → Trabajas a ciegas, sin visibilidad centralizada
- "SIEM existe pero 50% falsos positivos" → Analistas ignoran alertas

Gap de Respuesta:

- "No tenemos plan formalizado" → Cuando ocurra incidente = caos
- "No hemos hecho simulacro en 3 años" → Plan existe en papel, no en realidad

Gap de Recuperación:

- "RTO/RPO indefinido" → No sabes cuánto downtime es tolerable
- "Backups sin pruebas" → Descubrirás que no funcionan cuando los necesites (Murphy's Law aplicada)

ACTO V: EL ROI MÁGICO (O POR QUÉ GASTAR €500K EN SIEM TIENE SENTIDO)

La Ecuación que Fascina al CFO

Riesgo Anual Sin Control (ALE) = €2,000,000
↓
(Ransomware 20% × €10M)

Implementar SIEM + EDR (Costo) = €150,000/año
↓
Reducción Riesgo (SIEM detecta 80%) = €1,600,000/año
↓
Net Benefit = €1,600,000 - €150,000 = €1,450,000
↓
ROI = 1,450,000 / 150,000 × 100 = 967% (casi 10x inversión)
↓
Payback = 150,000 / (1,600,000/365) = 34 días

Conversación con CFO:

- CFO: "¿€150k en SIEM?"
- CISO (armado con números): "Sí, pero evita potencial €2M en ransomware. ROI: 967%."
- CFO: "... Ok, adelante."

ACTO VI: CASOS DE USO Y ESCENARIOS REALES

Caso 1: Startup Tech (IGM 1.5 - Caótica)

Perfil: 50 personas, crecimiento rápido, "seguridad después de un incidente"

Gap Principal: No hay gobernanza. "El CTO maneja todo" (conflicto de intereses)

Recomendación: Implementar básicos (MFA, política) antes de recibir financiación series A o requisito cliente "SOC 2".

Timeline: 3 meses, €50k

Caso 2: Empresa Grande (IGM 3.1 - Gestionada)

Perfil: 5.000 empleados, sector financiero, cumplimiento regulatorio obsesivo

Gap Principal: Demasiado compliance, poco "detection". SIEM existe pero 40% falsos positivos.

Recomendación: Optimizar SIEM (tunning de reglas), introducir UEBA, pasar de "compliance checkbox" a "detección efectiva".

Timeline: 6 meses, €300k

Caso 3: Operador CRITIS (IGM 2.8 - Necesita urgencia)

Perfil: Energía, 10.000 empleados, objetivo estado/delincuencia sofisticada

Gap Principal: Mucho perimetral, poco interno. OT segregada pero sin monitorización. Red team inexistente.

Recomendación: Inversión en OT security, SIEM OT dedicada, red team semestral, adversary simulation.

Timeline: 18 meses, €2M+

EPÍLOGO: POR QUÉ ESTO IMPORTA (LA PARTE SERIA)

A pesar del tono irónico: **La ciberseguridad que no se mide es la ciberseguridad que fracasa.**

Razones Reales:

10.
Dinero: Sin métricas, no justificas presupuesto. Sin presupuesto, no contratas talento. Sin talento, fracasas.
11.
Responsabilidad Ejecutiva: Directivos ahora personalmente responsables penalmente (NIS2, GDPR). Necesitan saber "¿realmente estamos seguros?" con números, no "feeling".
12.
Confianza Mercado: Clientes, partners, inversionistas quieren saber: "¿Qué es tu IGM?" Si es <2.5, es bandera roja. Si es >3.5, genera confianza.
13.
Preparación para Incidentes: No si, cuando ocurra un incidente, tus métricas (MTTD, MTTC, MTTR) determinarán daño real vs. potencial. La diferencia puede ser millones.
14.
Cumplimiento Regulatorio: NIS2, GDPR, CRA exigen "demostrables controles". Encuesta + IGM = evidencia concreta ante auditoría.

Dinero: Sin métricas, no justificas presupuesto. Sin presupuesto, no contratas talento. Sin talento, fracasas.

Responsabilidad Ejecutiva: Directivos ahora personalmente responsables penalmente (NIS2, GDPR). Necesitan saber "¿realmente estamos seguros?" con números, no "feeling".

Confianza Mercado: Clientes, partners, inversionistas quieren saber: "¿Qué es tu IGM?" Si es <2.5, es bandera roja. Si es >3.5, genera confianza.

Preparación para Incidentes: No si, **cuando** ocurra un incidente, tus métricas (MTTD, MTTC, MTTR) determinarán daño real vs. potencial. La diferencia puede ser millones.

Cumplimiento Regulatorio: NIS2, GDPR, CRA exigen "demostrables controles". Encuesta + IGM = evidencia concreta ante auditoría.

MORALEJA

La encuesta integral de ciberseguridad es:

-  Herramienta de medición rigurosa (GQM + NIST CSF)
-  Mapa de carreteras de mejora (roadmap 18 meses)
-  Justificación presupuestaria (ROI >500% típicamente)

-  Defensa legal (compliance auditable)
-  Instrumento de comunicación ejecutiva (números que entienden)

Es también:

-  Punto en el tiempo (requiere validación externa)
-  Subjetiva en partes (requiere calibración)
-  No garantiza evitar incidente (mitigación de riesgo, no eliminación)

Pero si no lo haces: Al menos los números de "por qué fallamos" estarán disponibles para la auditoría post-brecha.

Fin de Narrativa Explicativa

Recordatorio Amistoso: La ciberseguridad es como el fitness. No es una meta, es un viaje. Medir el viaje te ayuda a no quemarte en el proceso.

Escrito con ironía constructiva, rigor metodológico y genuina preocupación por la postura cibernética de las organizaciones españolas.